

CVE vs VEX

CVE 是已知軟體與硬體漏洞的標準編目系統。

VEX 則用來評估這些漏洞在特定產品中的實際可利用性。

兩者結合有助於過濾假陽性，提升供應鏈安全管理效率。

CVE 是什麼？

CVE (Common Vulnerabilities and Exposures，通用漏洞與暴露) 是一個公開字典，為軟體、硬體或系統中的已知安全漏洞分配唯一識別碼，如 CVE-2021-44228。

每個 CVE 條目包含漏洞描述、嚴重性分數 (如 CVSS) 及潛在影響，供掃描工具追蹤與修補。由 MITRE 維護，涵蓋可獨立修復且經供應商確認的漏洞。

VEX 是什麼？

VEX (Vulnerability Exploitability eXchange，漏洞利用性交換) 是標準格式，讓供應商宣告特定產品是否受 CVE 影響。

狀態包括「不受影響」 (Not Affected)、「受影響」 (Affected)、「已修復」 (Fixed) 或「分析中」 (Under Investigation)。

2021 年由美國 NTIA 推動，常與 SBOM 整合，減少掃描噪音。

主要差異

面向	CVE	VEX
目的	記錄漏洞細節	評估產品特定影響
內容	描述與分數	狀態與理由
輸出	漏洞清單	證明文件
應用	掃描修補	優先排序與例外

應用場景

VEX 幫助過濾如 Log4Shell 在特定版本中無影響的 CVE，適用於容器與 Kubernetes 環境。

供應商如 Red Hat 已發布 VEX beta 文件，提升回應速度。

支援 CycloneDX 等格式，實現自動化漏洞管理。